

RAW-DATA INDUSTRY THREAT HUNT

THE BANK IS NOT THE BATTLEGROUND

A hunt across **113.7 million raw scan documents** — starting from favicon hashes, cloned page titles and DOM fingerprints rather than pre-built campaigns. The dominant threat to UK and EU financial-services consumers is not bank credential phishing. It is industrialised investment fraud that impersonates **national broadcasters** and casts **real bank CEOs** as villains.

113,759,479 documents 70,482,417 unique domains 5 hunting surfaces 0 campaigns used as seed

10+

countries hit by one localised fraud template

5

real bank CEOs cast as villains: UniCredit, BNP, AIB, ING, UBS

41×

over-representation of .ink vs corpus baseline

28d

a domain sat dead before flipping to a live bank login page

01 METHOD — HUNTING RAW, NOT READING CAMPAIGNS

Starting from tracked campaigns inherits someone else's clustering and can only rediscover the known. Every finding here was derived from primary scan artifacts across

five independent surfaces, each able to find malice with no prior knowledge of the actor.

SURFACE	FIELD	WHY IT FINDS BAD
Favicon pivot	<code>favicons.mmh3</code>	Kits copy the bank's favicon verbatim. Genuine hash on a non-brand domain is near-conclusive.
Cloned-title hunt	<code>page_title.keyword</code>	Kits clone the whole page including <code><title></code> .
Content fingerprints	<code>fingerprint.dom</code> / <code>scripts</code> / <code>links</code>	Groups domains rendering the same kit; survives rotation. Walked as a graph.
Request forensics	<code>request.request.url</code> / <code>post_data</code>	Exposes where harvested data is sent.
Statistical baselining	<code>tld</code> · <code>tag</code> · <code>aggregations</code>	Defines normal across 70M domains so deviation is measured, not asserted.

Operational note — not all fingerprints are equal. From one seed page: `dom`, `scripts`, `links` and `tech` each returned exactly **3 domains** (the kit) — while `ssl` returned **7,332**, because it fingerprints Cloudflare's TLS presentation, not the kit. Hunt on `DOM/scripts/links`; use `SSL` only to corroborate.

02

FINDING 1 — THE PAN-EUROPEAN FAKE-NEWS FRAUD NETWORK

A template-driven content farm manufacturing fake investigative journalism, localised per country, funnelling retail victims into unauthorised trading platforms. One narrative formula: a famous journalist confronts a named bank CEO live on television; the CEO

storms off; the "secret" wealth platform citizens are being denied is revealed. The people, programmes and banks are real. The story is not.

COUNTRY	IMPERSONATED MEDIA / PUBLIC FIGURE	NAMED INSTITUTION
IT	Report (RAI 3), Piazzapulita, Corrado Formigli	UniCredit
FR	Élise Lucet	BNP Paribas
IE	RTÉ Late Late Show, David McWilliams	AIB
NL	NPO, Geert Wilders	ING
CH	Blick, SRF Arena	UBS
BE	Raoul Hedebouw, Marc Coucke	BitKeltTrade platform
IT	PM Giorgia Meloni	"state support platform"
DK / MX / AR / ZA	Milenio, Sheinbaum, Milei, LN+	local-currency income claims

“You're stealing people's money every day”: AIB chief executive storms off Late Late Show after David McWilliams...

«U liegt tegen miljoenen Nederlanders»: Hoe Geert Wilders de CEO van ING live op NPO kapotmaakte

Four fingerprinted sub-clusters

Recovered by three-wave fingerprint graph walk from 14 seeds — 76 domains total.

LINKS FINGERPRINT	DOM.	WINDOW
f06f7b86...	31	Feb 05 – Jul 24
5648ef7c...	31	Jan 07 – Feb 21
4d0039f0...	9	May 19 – Jul 30
5eb0a1c8...	5	Jul 28 (one day)

Tradecraft

The domain name is part of the deception, not just an address.

Credibility-signalling names: `fonteverificata.ink` ("verified source"), `notiziacertificata.ink` ("certified news"), `cronacatrasparente.ink` ("transparent chronicle"), `bereport.today`, `factpoint.cyou`.

Direct programme impersonation: `piazzapulita.buzz` (real Italian TV show), `ch-blick.today` (Swiss newspaper).

Coined disposables: `birchferry` · `cedarspark` · `velvethatch` · `sablecreek` · `zanifruk` · `terivux`.

Burst deployment: the French sub-cluster's five domains all appeared on a single day.

Why this outranks credential phishing. The victim is never asked to visit their bank, so every control built around the login moment — 2FA, device binding, perimeter monitoring — is bypassed, and "always check your bank's URL" is irrelevant. The money leaves as an authorised push payment the victim makes themselves, to a platform they believe a national broadcaster just validated.

03 FINDING 2 — GERMAN CREDENTIAL PHISHING: SMALL, PRECISE, AGED

Found by favicon pivot, expanded by title clone and DOM fingerprint: 13 domains serving the genuine title `Anmeldung zum Digital Banking – Commerzbank`, built on one kit.

Domain aging — dead first, weaponised later

`115224-crypto.com` — detection built on domain age misses this entirely.

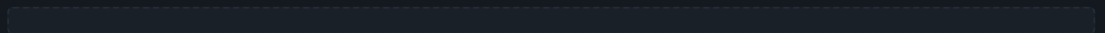
Mar 02 – Mar 29



Mar 30 – Apr 21



Apr 22 – Jul 27



28 days dead (HTTP 521) → **22 days** live Commerzbank login page → abandoned.

Cross-cutting TTP — consonant-skeleton abbreviation. Three unrelated brand families independently register abbreviated brand skeletons across multiple TLDs at once: Commerzbank `cmrz-* .info`, Sparkasse `spk-enggo.biz/.info/.net/.org`, Bitpanda `bpda*` in paired `.biz/.org`. This is a deliberate defeat of exact-brand-string monitoring — which is what most brand-protection services actually run. Bitpanda is additionally attacked by **l→i homoglyph** (`bltpandaaps.com`, `bltpandapro.com`) under a "Regulatory Update" pretext.

TLD lift vs corpus baseline

Confirmed-bad FS set (n=419) against 70.4M-domain baseline. Grey = under-represented.



What the lift means

.ink and .link are effectively the **signature TLDs of the fake-news fraud network** — rare in the wild, heavily concentrated here.

.de at 18x is **ccTLD-as-credibility**: a German victim expects their bank on .de, so the attacker pays for one.

The inversion matters most. .top — the most abused TLD in illicit gambling (25.6% of that estate) — is **five times under-represented** here. Attacker TLD choice is sector-specific: do not import gambling-derived weightings into financial-services scoring.

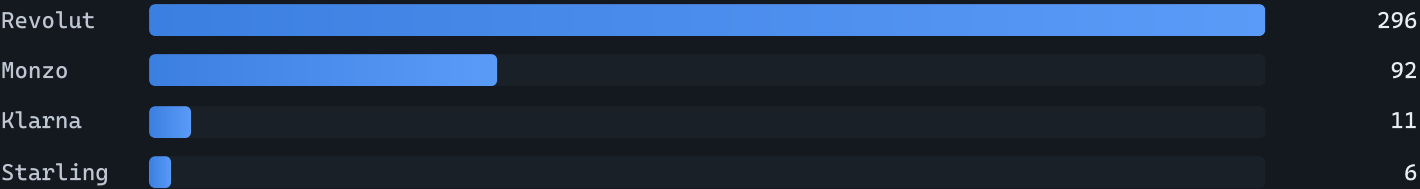
Baselines that changed the analysis

92.9% of all 70.4M unique domains carry a newly-registered-domain tag. So "this brand's lookalikes are overwhelmingly newly registered" is **not a finding** — it is the background. Any NRD argument must be made against 92.9%, not zero.

meta.risk_score does not discriminate. Across 50 brand cohorts the mean sat between 6 and 34, and the confirmed-live Commerzbank phishing page scored **16**. Risk score cannot triage this threat class.

Neobank brands parasited for gambling

Trusted UK fintech branding legitimising unlicensed gambling — many posing as Google Play listings.



05 REJECTED HYPOTHESES

Recording what did not survive validation is part of the method. Each of these was initially compelling.

TESTED AND DISCARDED

1. **"Brand-embedded DGA network."** Domains like ...bbva..., ...hmr..., ...pkobp... inside 32-char random strings looked like one actor spraying FS brands. **Rejected:** the pattern matches **9,001,534 domains** corpus-wide — the generic bulk-DGA/parked population. Chance alone predicts ~150 collisions per 4-letter token. The "campaign" was arithmetic. All later hunts exclude 28+ char SLDs.
2. **"FS lookalikes are ~97% newly registered."** True but meaningless against a 92.9% baseline.
3. **"fingerprint.ssl clusters the kit."** It returns 7,332 unrelated domains — it fingerprints Cloudflare's TLS profile, not the phishing kit.

Standing hunt queries — Webamon scans index

Content-hash pivots survive the domain rotation that defeats blocklists.

```
# Fake-news investment fraud - network-wide pivots
fingerprint.links:"f06f7b8641292798fe8071f5..." # multi-country CEO confrontation
fingerprint.links:"5648ef7c16fabbc1bdf7cab7..." # Italian gov / Meloni platform
fingerprint.links:"4d0039f0784587baa75823b8..." # NL / CH / BE
fingerprint.links:"5eb0a1c82a0e8b72a3771185..." # France / Élise Lucet

# Commerzbank credential kit (precise - 3-domain convergence)
fingerprint.dom:"d89d988a68eb43eee2d76ee2b15f0897..."

# Cloned-login detection - repeat per brand
page_title:"Anmeldung zum Digital Banking" AND NOT domain_name:*commerzbank*

# Abbreviated-brand + homoglyph families
domain_name:cmrz-* OR domain_name:spk-* OR domain_name:bpda*
domain_name:blt*panda* OR domain_name:bltpanda*
```

Favicon pivot — genuine hashes for continuous monitoring

Alert whenever these appear on a domain that does **not** contain the brand token.

BRAND	FAVICON.S.MMH3	BRAND	FAVICON.S.MMH3
HSBC	-1880472501, -892619762	Commerzbank	-56121909, 1277459174
Barclays	1118519999, -498795244	N26	-1711966902, -1195976521
Lloyds	1118331850, -833056250	Klarna	1246623548, 1674545617
NatWest	515660302, 1440580516	ABN AMRO	1329536365, 605706571

BANKS & FINTECHS

1. **Monitor your favicon hash**, not just your brand string — it caught impersonation name-based monitoring missed entirely.
2. **Monitor consonant-skeleton abbreviations** across TLDs (cmrz-, spk-, bpda) — the control these actors explicitly defeat.
3. **Treat executive names as brand assets**. Your CEO is being cast as a villain in fabricated broadcast journalism.

DETECTION ENGINEERING

1. **Don't rely on domain age** — 28 days dormant, then 22 days live.
2. **Don't rely on risk scoring** — confirmed live phishing scored 16/100.
3. **Hunt dom/scripts/links, never ssl alone** (3 vs 7,332 domains from one seed).
4. **Weight .ink .link .cyou .buzz .de**; treat .top as a negative indicator here.

FRAUD & CONDUCT

1. **The dominant harm is investment fraud**, not credential theft — login-perimeter controls don't touch it.
2. **Coordinate with broadcasters and regulators** — RAI, RTÉ, NPO, SRF and named politicians are impersonated, opening takedown routes a bank lacks alone.
3. **Watch the gambling bridge** — shared kit fingerprints indicate common suppliers.